

סריקה, מיפוי והערכת חולשות

מודול 6 — Scanning & Enumeration

◀ Nmap לעומק

◀ מנייה: HTTP, SMB, SSH, FTP

◀ Nessus — סריקת חולשות

◀ Searchsploit — חקר חולשות

שלב הסריקה

- ◀ מ-Recon פסיבי למגע אקטיבי עם היעד
- ◀ **Scanning** — מכונות ופורטים
- ◀ **Enumeration** — חפירה עמוקה בכל שירות
- ◀ "Enumerate, enumerate, enumerate" 💡

Nmap — יסודות

גילוי מארחים — `nmap -sn 192.168.1.0/24` ◀

כל 65,535 הפורטים — `nmap -p-` ◀

SYN · `-sT` Connect · `-sU` UDP `-sS` ◀

SYN-ACK=פתוח, RST=סגור (מודול 3) ◀

Nmap — מנייה

◀ `-sV` גרסאות · `-O` מערכת הפעלה

◀ `-sC` סקריפטים · `-A` אגרסיבי

◀ **המומלץ:** `nmap -sC -sV -oN scan.txt <ip>`

◀ גרסאות ישנות = חולשות ידועות

NSE — Nmap Scripting Engine

חולשות ידועות — `--script vuln` ◀

`--script smb-enum-shares` ◀

EternalBlue — `--script smb-vuln-ms17-010` ◀

הסקריפטים ב- `/usr/share/nmap/scripts/` ◀

מניית HTTP/HTTPS

whatweb — טכנולוגיות ◀

nikto -h — חולשות web נפוצות ◀

gobuster dir -w ... — ספריות נסתרות ◀

בדוק ידנית: source, /robots.txt ◀

מניית SMB

◀ פורטים 139/445, שיתוף קבצים Windows

◀ — משתמשים, שיתופים `enum4linux -a`

◀ `smbclient -L //ip/`

◀ **MS17-010 (EternalBlue)** → WannaCry ⚠

מניית SSH ו-FTP

Brute Force יעד + גרסה — SSH (22) ◀

Anonymous login בדוק — FTP (21) ◀

`nmap --script ftp-anon` ◀

גרסה ישנה = חולשה אפשרית ◀

Nessus — סריקת חולשות

◀ סורק אוטומטי, מדרג Critical → Info

◀ Essentials חינומי (16 IPs)

◀ `https://localhost:8834`

◀ ⚠ רועש; לא תחליף למנייה ידנית

חקר חולשות → Exploit

searchsploit apache 1.3.20 ◀

Exploits-ה — מאגר ה-Exploit-DB ◀

CVE — מזהה ייחודי (CVE-2017-0144) ◀

הגשר בין מנייה לניצול (מודול 7) ◀

סיכום מודול 6

◀ Nmap = הליבה (פורטים → גרסאות → NSE)

◀ מנייה לפי שירות: HTTP/SMB/SSH/FTP

◀ Nessus עוזר; searchsploit מגשר ל-Exploit

◀ **תעד הכל לדוח**

◀ **תרגילים** → missions.md · **פתרונות** → solutions.md